VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

Target: Metasploitable 2 (Intentionally Vulnerable VM)

Tool: Nessus Essentials (Basic Network Scan)

Scan Date: March 11, 2026 | Duration: 14 minutes

Total Vulnerabilities Found: 68

Detail	Value
Report Type	VAPT — Vulnerability Assessment & Penetration Testing
Scanner	Nessus Essentials (Local Scanner)
Policy	Basic Network Scan
Severity Base	CVSS v3.0
Scan Start	March 11, 2026 — 11:17 PM
Scan End	March 11, 2026 — 11:31 PM
Elapsed Time	14 minutes
Total Vulnerabilities	68
Hosts Scanned	1 (Metasploitable 2)
Environment	VirtualBox Lab (Isolated Network)
Author	Pa1 — CEH Student, Win in Life Academy
Classification	Confidential — For Educational Use Only

1. Introduction

This report documents a comprehensive Vulnerability Assessment and Penetration Testing (VAPT) exercise conducted on a Metasploitable 2 virtual machine using Nessus Essentials. The entire exercise was performed in an isolated VirtualBox lab environment for educational and portfolio-building purposes as part of a Certified Ethical Hacker (CEH) training program.

The objective of this assessment was to:

- Identify security vulnerabilities present on a deliberately insecure Linux-based system.
- Understand the severity and exploitability of each discovered vulnerability.
- Map vulnerabilities to real-world attack scenarios.
- Recommend appropriate remediation strategies.

Penetration testing, when conducted ethically and with proper authorization, is an essential practice in modern cybersecurity. It allows security professionals to think like attackers, discover weaknesses before malicious actors do, and provide actionable intelligence to system administrators and development teams.

All testing in this report was performed in a controlled, isolated virtual network. No external or production systems were targeted. This report is intended for educational review and as a cybersecurity portfolio artifact.

2. Nessus Essentials — Tool Overview

Nessus Essentials is the free-tier version of Tenable's industry-leading vulnerability scanner, Nessus Professional. It is widely used by security students, researchers, and professionals for identifying vulnerabilities in networked systems.

2.1 Key Features

- Scans up to 16 IP addresses (sufficient for lab environments).
- Supports over 59,000 Common Vulnerabilities and Exposures (CVE) checks.
- Uses CVSS v3.0 as the severity baseline for vulnerability scoring.
- Provides automated remediation suggestions and grouping by vulnerability family.
- Generates detailed HTML and PDF reports for documentation.
- Includes plugin-based detection for misconfigurations, outdated software, and exposed services.

2.2 Scan Policy Used

For this assessment, the Basic Network Scan policy was selected. This policy performs:

- Port discovery across common and well-known ports.
- Service and version fingerprinting.
- Vulnerability detection based on known CVEs.
- SSL/TLS configuration analysis.
- Detection of backdoors, default credentials, and insecure services.

Parameter	Value
Scanner Type	Local Scanner (installed on host machine)
Scan Policy	Basic Network Scan
Severity Base	CVSS v3.0
Credentialed Scan	No (unauthenticated scan)
Target	Metasploitable 2 VM IP

3. Target System — Metasploitable 2

Metasploitable 2 is an intentionally vulnerable Linux virtual machine created by Rapid7 (the creators of Metasploit Framework). It is designed specifically for practicing penetration testing, vulnerability scanning, and exploitation techniques in a safe, legal environment.

3.1 System Overview

Property	Details
OS	Ubuntu 8.04 LTS (Hardy Heron) — Outdated, unsupported
Purpose	Intentionally vulnerable VM for ethical hacking practice
Distribution	Rapid7 / Metasploit Community
Hosting	Oracle VirtualBox (Isolated NAT Network)
Network Mode	NAT Network (VirtualBox) — isolated from host/internet
Open Services	FTP, SSH, Telnet, HTTP, SMB, MySQL, PostgreSQL, VNC, etc.
Default Credentials	msfadmin:msfadmin (intentionally weak)

3.2 Lab Environment Setup

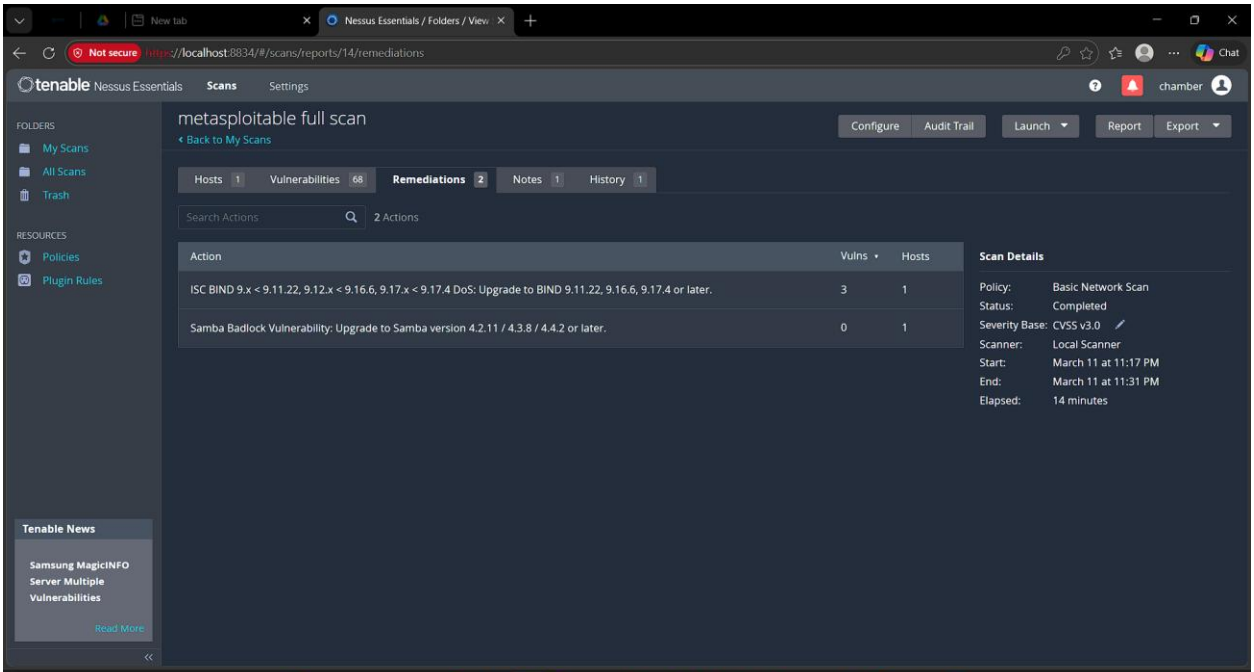
The following lab configuration was used to perform this assessment:

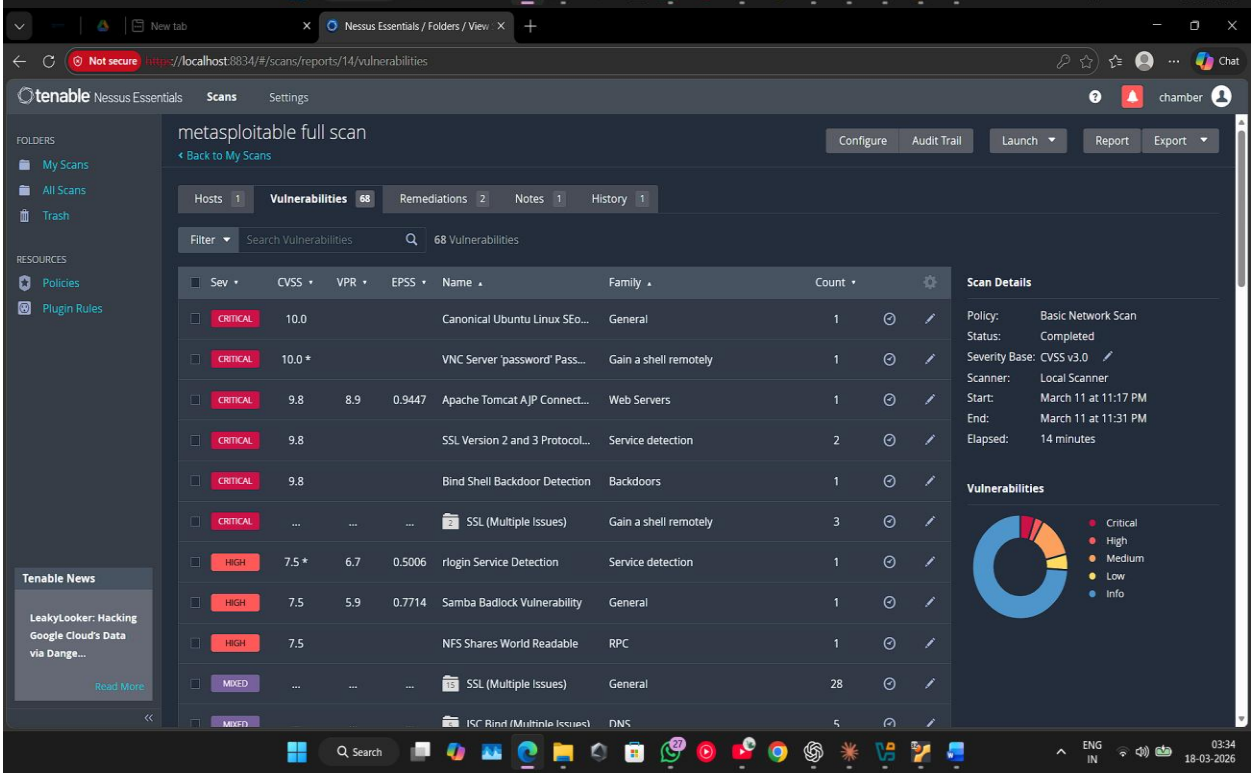
- Host Machine: Windows 11 with VirtualBox installed.
- Attacker Machine: Kali Linux VM (configured on NAT Network).
- Target Machine: Metasploitable 2 VM (configured on the same NAT Network).
- Nessus Essentials: Installed on the host machine, accessible via browser at localhost:8834.
- Network Isolation: Both VMs placed on a VirtualBox NAT Network, ensuring no external traffic.

The NAT Network adapter mode was chosen over standard NAT to allow VM-to-VM communication — a critical requirement for scanning Metasploitable 2 from the Nessus scanner and Kali Linux.

4. Scanning Methodology

The vulnerability scan was conducted using a structured approach following standard VAPT methodology phases:





Phase 1 — Reconnaissance & Target Discovery

- Identified the IP address of Metasploitable 2 on the NAT Network.
- Confirmed host reachability using ping and Nmap pre-scan.
- Verified open ports using: nmap -sV -O <target_ip>

Phase 2 — Nessus Scan Execution

- Opened Nessus Essentials at https://localhost:8834.
- Created a new scan using the Basic Network Scan policy.
- Entered the target IP address of Metasploitable 2.
- Launched the scan — completed in 14 minutes.
- Reviewed results in the Vulnerabilities tab (68 vulnerabilities found).

Phase 3 — Results Analysis

- Sorted vulnerabilities by CVSS score (Critical first).
- Reviewed each finding — name, family, severity, CVSS, VPR, and EPSS scores.
- Cross-referenced CVE IDs with NVD (National Vulnerability Database).
- Mapped vulnerabilities to possible attack techniques.

Phase 4 — Reporting

- Documented all findings with detailed descriptions, risk context, and remediation steps.
- Reviewed Nessus Remediations tab for automated fix suggestions.
- Compiled this comprehensive VAPT report.

Severity	Count	CVSS Range
Critical	6	9.0 – 10.0
High	3+	7.0 – 8.9
Mixed (Multiple Issues)	2+	Varies
Medium / Low / Info	Remaining	Below 7.0
Total	68	—

5. Vulnerability Findings — Detailed Analysis

The following section provides detailed information on each significant vulnerability identified during the Nessus scan. Findings are organized by severity (Critical to Low).

5.1 Canonical Ubuntu Linux SEoL — CVSS 10.0 [CRITICAL]

Field	Details
Severity	CRITICAL
CVSS Score	10.0
Family	General
CVE	N/A (End-of-Life classification)
Affected Component	Ubuntu 8.04 LTS — operating system

Description

The target system is running Ubuntu 8.04 LTS (Hardy Heron), which reached End-of-Life (EOL) in May 2013. An end-of-life OS no longer receives security patches, bug fixes, or updates from the vendor. This means all newly discovered vulnerabilities affecting this OS version will never be patched, leaving the system permanently exposed.

Impact

- Every future CVE affecting Ubuntu 8.04 remains unpatched.
- The kernel, core libraries (glibc, OpenSSL), and services are all running outdated, vulnerable versions.
- Attackers can exploit known, documented vulnerabilities with publicly available exploit code (e.g., in Metasploit).

5.2 VNC Server 'password' Password — CVSS 10.0* [CRITICAL]

Field	Details
Severity	CRITICAL
CVSS Score	10.0 (adjusted)
Family	Gain a shell remotely
CVE	CVE-1999-0506 (Weak VNC Authentication)
Affected Service	VNC Server (default port 5900)

Description

The VNC (Virtual Network Computing) service running on Metasploitable 2 is configured with the default password 'password'. VNC provides full graphical remote desktop access to the system. A trivially guessable credential on a remote desktop service represents one of the most critical vulnerabilities in any networked system.

Impact

- An unauthenticated attacker on the network can gain full graphical desktop access.
- Complete system compromise — read/write files, execute commands, exfiltrate data.
- No exploitation tools required — any VNC client (e.g., RealVNC, TightVNC) suffices.

5.3 Apache Tomcat AJP Connector (Ghostcat) — CVSS 9.8 [CRITICAL]

Field	Details
Severity	CRITICAL
CVSS Score	9.8
VPR Score	8.9
EPSS Score	0.9447 (94.47% exploitation probability)
CVE	CVE-2020-1938
Family	Web Servers
Affected Service	Apache Tomcat AJP Connector (port 8009)

Description

CVE-2020-1938, nicknamed 'Ghostcat', is a critical file read/inclusion vulnerability in Apache Tomcat's AJP (Apache JServ Protocol) connector. When the AJP connector is exposed to the network, an unauthenticated attacker can read any file from the Tomcat web application or, in configurations with file upload, achieve Remote Code Execution (RCE).

Impact

- File disclosure — read sensitive configuration files (e.g., web.xml, WEB-INF contents).
- Potential Remote Code Execution if a file upload function exists on the app.
- EPSS of 0.9447 means there is a ~94% probability of this being exploited in the wild.

5.4 SSL Version 2 and 3 Protocol Detection — CVSS 9.8 [CRITICAL]

Field	Details
Severity	CRITICAL

CVSS Score	9.8
Family	Service Detection
CVE	CVE-2014-3566 (POODLE), CVE-2011-3389 (BEAST)
Count	2 affected services

Description

The target is running SSL 2.0 and SSL 3.0, protocols deprecated decades ago due to fundamental cryptographic weaknesses. SSLv2 was broken by design, and SSLv3 is vulnerable to the POODLE attack, which allows an attacker performing a man-in-the-middle (MITM) attack to decrypt encrypted traffic.

Impact

- POODLE attack — decryption of HTTPS sessions and cookie theft.
- BEAST attack — CBC-mode cipher exploitation.
- Credential interception on any service using SSLv2/v3 (HTTPS, SMTP, IMAPS, etc.).

5.5 Bind Shell Backdoor Detection — CVSS 9.8 [CRITICAL]

Field	Details
Severity	CRITICAL
CVSS Score	9.8
Family	Backdoors
Port	1524/TCP
CVE	N/A — Intentional Metasploitable backdoor

Description

A bind shell backdoor is listening on port 1524 of the target machine. This backdoor was intentionally placed in Metasploitable 2. When a user connects to this port using netcat or any TCP client, they are immediately dropped into a root shell — no authentication required whatsoever.

Personal Note

This vulnerability was previously exploited successfully in lab work. Connecting with 'nc <target_ip> 1524' immediately grants a root shell, confirmed with 'id' returning uid=0(root).

Impact

- Immediate, unauthenticated root-level access to the system.
- Complete system compromise — full read/write/execute control.
- Persistence, data exfiltration, lateral movement all become trivial.

5.6 SSL (Multiple Issues) — CVSS Critical/Mixed

Field	Details
Severity	CRITICAL / MIXED
Family	Gain a shell remotely / General
Count	3 + 28 affected instances
Issues	Self-signed certs, expired certs, weak cipher suites, deprecated protocols

Description

Multiple SSL/TLS misconfigurations exist across numerous services on the target. These include the use of self-signed certificates (no trusted CA), expired certificates, acceptance of weak cipher suites (RC4, DES, 3DES, NULL), and support for insecure renegotiation. With 28 mixed-severity SSL issues detected, the cryptographic posture of this system is severely compromised.

5.7 rlogin Service Detection — CVSS 7.5 [HIGH]

Field	Details
Severity	HIGH
CVSS Score	7.5*
VPR Score	6.7
EPSS	0.5006 (50% exploitation probability)
Family	Service detection
Port	513/TCP

Description

rlogin (Remote Login) is an ancient Unix remote access protocol from the 1980s that transmits all data — including credentials — in plaintext. It also supports host-based authentication via .rhosts files, which can allow login without any password if the attacker can spoof a trusted hostname or IP.

Impact

- Credential theft via packet sniffing (no encryption).
- Authentication bypass via .rhosts file manipulation.
- Direct remote shell access as any user.

5.8 Samba Badlock Vulnerability — CVSS 7.5 [HIGH]

Field	Details
Severity	HIGH
CVSS Score	7.5
VPR Score	5.9
EPSS	0.7714 (77% exploitation probability)
CVE	CVE-2016-2118
Family	General
Remediation	Upgrade to Samba 4.2.11 / 4.3.8 / 4.4.2 or later

Description

Badlock (CVE-2016-2118) is a significant vulnerability in Samba's DCERPC (Distributed Computing Environment/Remote Procedure Calls) implementation. An attacker performing a man-in-the-middle attack can intercept authentication attempts to SMB (Server Message Block) shares, downgrade the security negotiation, and gain unauthorized access to shared resources or capture NTLM password hashes for offline cracking.

5.9 NFS Shares World Readable — CVSS 7.5 [HIGH]

Field	Details
Severity	HIGH
CVSS Score	7.5
Family	RPC
Port	2049/TCP (NFS)
CVE	CVE-1999-0554

Description

Network File System (NFS) shares on the target are configured as world-readable — meaning any machine on the network can mount and browse the exported filesystem without authentication. Sensitive files, SSH keys, configuration files, or user data stored in these shares are fully accessible to unauthenticated network users.

Impact

- Unauthenticated access to exported filesystem contents.
- Potential SSH key theft enabling password-less access to the target or other systems.
- Information disclosure leading to privilege escalation.

6. Possible Attacks — Attack Surface Analysis

Based on the vulnerabilities identified, the following real-world attack scenarios are feasible against this target. These are presented for educational awareness only.

Attack Name	Vulnerability Exploited	Tool/Method	Impact
Bind Shell RCE	Port 1524 Backdoor	netcat (nc 1524)	Instant Root Shell
VNC Brute Force	Default VNC Password	VNC Client / Hydra	Full GUI Access
Ghostcat File Read	CVE-2020-1938 (AJP)	PoC Python script	File Disclosure / RCE
POODLE MITM Attack	SSLv3 Support	Wireshark + MITM tool	Session Hijack
Badlock MITM	CVE-2016-2118 (Samba)	Responder / Impacket	Hash Capture / SMB Access
NFS Mount Attack	World-Readable NFS	showmount + mount	Data Exfiltration
rlogin Sniff	rlogin Plaintext Auth	Wireshark / tcpdump	Credential Theft
ISC BIND DoS	CVE BIND < 9.11.22	Malformed DNS Query	DNS Service Crash
SSL Cipher Downgrade	Weak SSL Ciphers	SSLstrip / Bettercap	Traffic Decryption
Metasploit Exploit	Multiple CVEs	msfconsole	Shell / Root Access

Note: Exploiting the Port 1524 Bindshell has been verified in this lab environment. A connection attempt using netcat returned a root shell immediately, confirming this as a confirmed exploit (not just theoretical).

7. Remediations

The Nessus Remediations tab identified 2 automated remediation actions. The following section expands on these and provides comprehensive remediation guidance for all critical findings.

7.1 Nessus Automated Remediation Actions

Action	Affected Vulns	Hosts
ISC BIND 9.x < 9.11.22, 9.12.x < 9.16.6, 9.17.x < 9.17.4 DoS — Upgrade to BIND 9.11.22, 9.16.6, 9.17.4 or later	3	1
Samba Badlock Vulnerability — Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later	0	1

7.2 Comprehensive Remediation Guidance

OS End-of-Life (Ubuntu 8.04)

1. Migrate to a supported Ubuntu LTS release (22.04 LTS or 24.04 LTS).
2. Apply all available security updates immediately after migration.
3. Implement a patch management policy to prevent future EOL scenarios.

VNC Default Password

4. Change the VNC password immediately using the vncpasswd command.
5. Restrict VNC access to trusted IP addresses via firewall rules (iptables/ufw).
6. Replace VNC with SSH tunneling for remote access where possible.
7. Disable VNC entirely if remote GUI access is not required.

Apache Tomcat AJP (Ghostcat — CVE-2020-1938)

8. If AJP is not required, disable it entirely in server.xml by commenting out the AJP Connector.
9. If AJP is needed, upgrade Apache Tomcat to 9.0.31+, 8.5.51+, or 7.0.100+.
10. Restrict the AJP port (8009) to localhost only using requiredSecret attribute.

SSL/TLS Protocol Issues

11. Disable SSLv2 and SSLv3 on all services. Configure TLS 1.2 minimum; prefer TLS 1.3.
12. Remove weak cipher suites: RC4, DES, 3DES, EXPORT-grade, NULL ciphers.
13. Replace self-signed certificates with certificates from a trusted Certificate Authority (CA).

14. Implement HTTP Strict Transport Security (HSTS) headers on web services.

Bind Shell Backdoor (Port 1524)

15. Immediately kill the process listening on port 1524.
16. Audit /etc/inetd.conf and /etc/xinetd.d/ for unauthorized service definitions.
17. Implement a host-based firewall to block unexpected outbound/inbound connections.
18. Conduct a full system integrity check (AIDE, Tripwire) to detect further backdoors.

rlogin Service

19. Disable and uninstall rlogin, rsh, and rexec services immediately.
20. Replace with SSH for all remote access requirements.
21. Remove .rhosts and /etc/hosts.equiv files.

NFS World Readable Shares

22. Restrict NFS exports to specific trusted IP addresses in /etc/exports.
23. Add the root_squash and nosuid options to all NFS exports.
24. Ensure no sensitive data (SSH keys, config files) is stored in exported directories.
25. Consider replacing NFS with SFTP or SCP for file transfers.

Samba Badlock (CVE-2016-2118)

26. Upgrade Samba to version 4.2.11, 4.3.8, 4.4.2, or any later release.
27. Enforce SMB signing on all Samba connections to prevent MITM attacks.
28. Restrict SMB access to trusted network segments only.

7.3 General Security Hardening Recommendations

- Implement a firewall (UFW or iptables) with a default-deny inbound policy.
- Disable all unnecessary services and close unused ports.
- Enforce strong password policies and multi-factor authentication where possible.
- Conduct regular vulnerability scans (monthly minimum) to track new findings.
- Maintain an asset inventory and patch management schedule.
- Implement network segmentation to limit blast radius of a compromise.
- Enable audit logging (auditd) and centralize logs to a SIEM.

8. Conclusion

This Vulnerability Assessment and Penetration Testing exercise on Metasploitable 2 using Nessus Essentials uncovered a total of 68 vulnerabilities across a wide range of severity levels. The findings paint a clear picture of what an unpatched, misconfigured Linux system looks like from an attacker's perspective.

Key takeaways from this assessment:

- End-of-Life systems are fundamentally indefensible — the OS itself being unsupported (CVSS 10.0) creates an irreparable foundational weakness that no patch can fix.
- Default credentials remain one of the most exploitable vulnerabilities — the VNC 'password' issue required zero technical skill to exploit.
- Well-known CVEs like Ghostcat (CVE-2020-1938) with EPSS of 94% are actively exploited in the wild, making unpatched Tomcat instances extremely high risk.
- Backdoors like the Port 1524 bindshell are definitionally catastrophic — no other vulnerability on this system even compares in terms of ease of exploitation.
- Deprecated protocols (SSLv2/v3, rlogin) that have been known-insecure for decades are still commonly found in real production environments.

From an educational standpoint, this exercise successfully demonstrated the end-to-end VAPT workflow: from scan configuration and execution, through vulnerability analysis and CVE research, to attack mapping and remediation planning. Each phase mirrors the methodology used by professional penetration testers and red team operators.

The findings from this lab translate directly to real-world skills. Understanding why a CVSS 9.8 score is assigned to Ghostcat, how POODLE exploits SSLv3, or why world-readable NFS shares are dangerous — this knowledge is foundational to both offensive and defensive security work.

This report serves as a portfolio piece demonstrating practical VAPT capability, documentation skill, and security awareness appropriate for a CEH certification candidate.

End of Report

Conducted in an isolated lab environment for educational purposes only.